

Industrial Security (Bachelor)

Exercise Sheet – Section 03 Industrial Network Architectures

Goal. These exercises practise the language of segmented OT networks: the Purdue layers, the iDMZ broker, IEC 62443 zones and conduits, the choice between a stateful firewall and a hardware diode, plus the everyday details (VLAN ACLs, PTP/NTP, SPAN/TAP, wireless, vendor remote access) that decide whether the design actually holds in production. Most questions are scenario-driven; cite the slides and reference advisories where they help.

Exercise 3.1 – Place the Assets on Purdue Levels

For a mid-size bottling plant, place each of the ten assets below onto a Purdue level (0–5) and write one short sentence per asset justifying the placement. Flag the three you find most ambiguous and explain why.

1. Hirschmann RSP35 managed switch on the filling line.
2. Siemens S7-1500 PLC running the capper.
3. Wonderware InTouch HMI on the line operator's desk.
4. OSIsoft PI Historian replicating to corporate.
5. Microsoft WSUS server feeding patches into the plant.
6. Phoenix Contact mGuard vendor jump host.
7. SAP S/4HANA production planning module.
8. Tofino industrial firewall in front of the SIS controller.
9. A handheld torque wrench reporting bolt data over Wi-Fi 6.
10. The corporate Microsoft 365 mail tenant.

Exercise 3.2 – Vendor PLC Firmware Update Once a Year

A field-service engineer from Siemens needs to push a firmware update to a PLC at Level 1, once per year, during a planned outage. Draw the full data flow you would permit (boxes, arrows, levels, iDMZ). Then:

1. State exactly three firewall rules (source, destination, protocol/port, direction, time-window) that enable the update without leaving a permanent hole.
2. Specify one logging or attestation requirement that proves after the fact that only the intended firmware reached the PLC.
3. Name the single control that prevents the vendor's laptop from talking directly to the PLC.

Exercise 3.3 – Migration from Flat OT to Segmented Purdue

You inherit a brownfield plant: one /22 subnet shared by PLCs, HMIs, the historian, the engineering workstation, and – through a single Cisco ASA – corporate IT. There is no iDMZ. Write a four-step migration plan to a properly segmented Purdue architecture. For each step give: scope of change, expected downtime, and rollback. Mark the single riskiest cutover step and say why it is risky.

Exercise 3.4 – Diode vs. Stateful Firewall for Historian Replication

The plant historian (Level 3) must replicate data to a corporate reporting database (Level 5). Compare an Owl or Waterfall data diode against a Fortinet stateful firewall on four axes: *direction guarantee*, *protocol support*, *operational cost*, *forensic value*. Give one concrete plant scenario in which the diode is the right choice and one in which the stateful firewall is the right choice. Three to five sentences per scenario.

Exercise 3.5 – Spot the Segmentation Failure

A junior engineer configures a Cisco Catalyst trunk between the plant access switch and the iDMZ aggregation switch. Native VLAN on both sides is left as VLAN 1. DTP is left at default (`dynamic auto`). VLAN 10 is the PLC VLAN, VLAN 20 is the HMI VLAN, VLAN 99 is the management VLAN. The ACL between VLAN 10 and VLAN 20 reads:

```
1 permit tcp 10.10.20.0 0.0.0.255 10.10.10.0 0.0.0.255 eq 502
2 permit ip any any
3 deny ip any any
```

Identify (a) the L2 attack the trunk configuration enables, (b) the ACL error that defeats the segmentation, and (c) at least two specific traffic flows that get through that should not. Three to six sentences total.

Exercise 3.6 – Time Sync in a Substation

A 110 kV substation reports that IED event timestamps disagree by up to 50 ms across bays. Operators use the records for protection-relay forensics and for IEC 61850 sequence-of-events analysis.

1. List three downstream failure modes that 50 ms of clock skew can cause (forensic, protection, or compliance).
2. Propose one concrete fix using IEEE 1588 PTP, including the role of the grandmaster, the switch capability you require, and where NTP is still acceptable.

Exercise 3.7 – Wi-Fi on the Plant Floor: One-Page Argument

The maintenance team wants Wi-Fi coverage across the plant floor so technicians can use tablets with a mobile HMI. Write a structured one-page argument: *for*, *against*, or *under what conditions*. Cover at least: which Purdue level the SSID terminates at, segregation from the production VLAN, authentication (EAP-TLS vs. PSK), what loops you would and would not close over Wi-Fi 6, and the rollback plan if a rogue access point appears. Reference one OT-aware vendor option (Cisco Catalyst IW, Hirschmann BAT, Moxa AWK).

Exercise 3.8 – CISA AA22-103A: Architecture Controls

Read CISA advisory AA22-103A (“APT Cyber Tools Targeting ICS/SCADA Devices”, 13 Apr 2022). List the network-architecture controls – not the IOCs – that would have raised the attacker’s cost, mapping each to the relevant Purdue layer or zone/conduit. Aim for five controls; for each, write one sentence on *what* and one on *why it helps against the specific tools described* (PIPEDREAM/INCONTROLLER, the Schneider and OMRON modules).

Exercise 3.9 – Bandwidth Floor for SCADA Poll and IDS Mirror

A Level 2 SCADA server polls 50 PLCs over Modbus TCP at 1 Hz. Each poll is a single **Read Holding Registers** request returning 100 registers (200 bytes payload). Assume 40 bytes of TCP/IP overhead per direction and ignore link-layer overhead.

1. Compute the floor link bandwidth in kbit/s required for the poll traffic in steady state.
2. Compute the floor bandwidth the SPAN/TAP mirror feed needs to carry a lossless copy to a Nozomi or Claroty IDS.
3. State one realistic reason the practical floor is higher than your numbers and one situation in which a 100 Mbit/s SPAN port would still drop frames.

Exercise 3.10 – Zones and Conduits for the Bottling Plant

Using your asset placement from Exercise 3.1, define at least four IEC 62443 zones with target Security Levels (SL-T 1–4). For every conduit between zones, give: allowed protocols, source, destination, direction, and the enforcement device (Hirschmann/Belden Tofino, Cisco ISA-3000, Palo Alto, Owl diode, Phoenix Contact mGuard). Identify one conduit where a data diode is the correct enforcement and one where a stateful firewall is sufficient; justify both in two to three sentences each.